

MODULE 10.3

Cybersecurity Countermeasures

Endpoint Security | Cisco Networking Academy

Prepared by: Kudzaishe Majeza

Cybersecurity Essentials

Topics Covered:

- 10.3 Cybersecurity Countermeasures
 - 10.3.2 Hardware-Based and Software-Based Technologies
 - 10.3.3 Establishing a Culture of Cybersecurity Awareness
 - 10.3.5 Policies
 - 10.3.6 Standards
 - 10.3.8 Guidelines
 - 10.3.9 Procedures

10.3 Cybersecurity Countermeasures

The Three Pillars of Defence

10.3

What Are Cybersecurity Countermeasures?

Countermeasures are the safeguards and controls that organisations put in place to protect data, systems, and people from cyber threats. They span three categories: technology (hardware and software tools), people (culture and awareness), and governance (policies, standards, guidelines, and procedures).

TECHNOLOGY

Hardware and software-based tools such as firewalls, IDS/IPS, antivirus, encryption hardware, and endpoint protection that form the technical layer of defence.

PEOPLE

A culture of cybersecurity awareness — training staff to recognise threats, follow safe practices, and understand their role in protecting the organisation.

GOVERNANCE

Policies, standards, guidelines, and procedures that define the rules, frameworks, and step-by-step processes everyone in the organisation must follow.

10.3.2 Hardware-Based and Software-Based Technologies

Technical Countermeasures for Cybersecurity

10.3.2

Technology as a Defence Layer

Technical countermeasures include both hardware devices and software applications that detect, prevent, and respond to cyber threats. They form the first and most visible line of defence in any cybersecurity strategy.

Firewalls

Filter incoming and outgoing network traffic based on rules. Hardware firewalls protect the network perimeter; software firewalls protect individual hosts. Essential for blocking unauthorised access.

IDS / IPS

Intrusion Detection Systems (IDS) monitor traffic and alert on suspicious activity. Intrusion Prevention Systems (IPS) go further and automatically block detected threats in real time.

Antivirus & Anti-Malware

Software that scans, detects, and removes malicious programs (viruses, ransomware, spyware, trojans). Must be kept up to date with the latest definitions to remain effective.

Encryption Hardware (TPM / HSM)

Trusted Platform Modules (TPM) and Hardware Security Modules (HSM) store cryptographic keys securely in hardware, protecting them from software-based extraction or tampering.

Endpoint Detection & Response (EDR)

Advanced endpoint protection that continuously monitors devices for threats, records activity for forensic analysis, and can isolate compromised endpoints automatically.

10.3.3 Establishing a Culture of Cybersecurity

Awareness

People Are the First Line of Defence

10.3.3

Why Culture Matters in Cybersecurity

Technology alone cannot protect an organisation. Employees who are unaware of threats are the most targeted attack vector — phishing, social engineering, and insider threats all exploit human behaviour. Building a cybersecurity-aware culture is essential.

Security Awareness Training

Regular, mandatory training for all staff covering phishing recognition, password hygiene, safe browsing, and incident reporting. Training must be updated as threats evolve.

Simulated Phishing Campaigns

Send fake phishing emails to employees to test their awareness. Those who fall for it receive immediate coaching — building real-world resilience without real-world consequences.

Clear Reporting Culture

Encourage staff to report suspicious activity without fear of blame. A culture where employees feel safe reporting mistakes catches incidents faster and reduces damage.

Role-Based Security Training

Tailor training to each role — finance staff learn about wire fraud; IT staff learn about patch management; executives learn about spear-phishing and CEO fraud.

Leadership Buy-In

Cybersecurity culture starts at the top. When executives and managers visibly follow security policies and champion awareness programmes, staff take them seriously.

10.3.5 Policies

The Rules That Govern Cybersecurity Behaviour

10.3.5

What Is a Cybersecurity Policy?

A cybersecurity policy is a formal document that defines the rules, expectations, and responsibilities for protecting an organisation's information and systems. Policies set the 'what' — the standards of behaviour everyone must follow.

Type 1

Acceptable Use Policy

Defines what employees may and may not do with company systems, networks, and data. Covers internet use, email, social media, and personal device use on corporate networks.

Type 2

Information Security

High-level document outlining the organisation's overall approach to protecting information assets, assigning responsibilities, and defining the security programme scope.

Type 3

Password Policy

Specifies minimum password length, complexity, expiry, and reuse rules. May mandate multi-factor authentication (MFA) for all or specific systems and accounts.

Type 4

Incident Response Policy

Defines how the organisation detects, reports, responds to, and recovers from cybersecurity incidents. Identifies roles, responsibilities, and escalation paths.

10.3.6 Standards

Benchmarks and Frameworks for Cybersecurity

10.3.6

What Are Cybersecurity Standards?

Standards are specific, measurable requirements that define how security controls must be implemented. They provide a consistent baseline that all systems and processes must meet, and are often derived from industry frameworks or regulatory requirements.

ISO/IEC 27001

International standard for Information Security Management Systems (ISMS). Provides a systematic approach to managing sensitive information using risk management processes. Widely adopted and globally recognised.

NIST Cybersecurity Framework

US National Institute of Standards and Technology framework built around five functions: Identify, Protect, Detect, Respond, and Recover. Widely used across industries as a flexible, risk-based approach to cybersecurity.

PCI-DSS

Payment Card Industry Data Security Standard — mandatory for any organisation that processes, stores, or transmits credit card data. Specifies controls for encryption, access control, monitoring, and vulnerability management.

HIPAA Security Rule

US Health Insurance Portability and Accountability Act security requirements for protecting electronic Protected Health Information (ePHI). Critical for organisations like XYZ, Inc. that work with hospitals and medical clients.

CIS Controls

Centre for Internet Security's prioritised set of 18 critical security controls. Provides practical, actionable steps organisations can take to defend against the most common and dangerous cyber attacks.

10.3.8 Guidelines

Best Practice Recommendations for Security

10.3.8

What Are Security Guidelines?

Guidelines are recommended practices that provide guidance on how to meet policies and standards. Unlike policies and standards, guidelines are not mandatory — they offer flexibility while still steering staff toward secure behaviours and decisions.

Password Best Practices

Recommend using a password manager, creating passphrases over complex strings, never reusing passwords across sites, and enabling MFA on all accounts where available.

Safe Email Handling

Advise staff to verify sender addresses before clicking links, avoid opening unexpected attachments, and report suspicious emails to IT immediately rather than deleting them.

Secure Remote Working

Recommend using a VPN when working remotely, locking screens when unattended, avoiding public Wi-Fi for sensitive work, and using company-approved devices only.

Software Update Guidance

Encourage prompt installation of security patches and operating system updates. Guide staff to enable automatic updates where possible and avoid delaying critical patches.

Clean Desk Policy

Recommend clearing desks of sensitive documents at end of day, locking computers when away from the desk, and disposing of printed documents via secure shredding.

10.3.9 Procedures

Step-by-Step Processes for Security Operations

10.3.9

What Are Security Procedures?

Procedures are detailed, step-by-step instructions that describe exactly how to carry out a specific security task. They translate policies and standards into actionable steps that any employee can follow consistently and correctly.

Incident Response Procedure

Step-by-step guide for responding to a security incident: Identify -> Contain -> Eradicate -> Recover -> Report -> Lessons Learned. Ensures a consistent, rehearsed response regardless of who is on duty.

User Account Provisioning

Formal steps for creating, modifying, and deactivating user accounts. Includes manager approval, role assignment, MFA setup, and access review scheduling to enforce least privilege from day one.

Patch Management Procedure

Defines how security patches are tested in a staging environment, approved, scheduled, and deployed across all systems within defined timeframes based on severity (critical, high, medium, low).

Backup and Recovery Procedure

Documents the schedule, method, and storage location for backups; defines RTO and RPO targets; and specifies the steps to restore data from backup, including verification of data integrity after restore.

Secure Disposal Procedure

Step-by-step process for securely wiping or destroying storage media (HDDs, SSDs, USB drives) before disposal or reuse — using DoD 5220.22-M wiping standards or physical destruction for highly sensitive data.

Module 10.3 — Summary

10.3 Countermeasures	Countermeasures span technology, people, and governance — all three must work together to protect the organisation.	10.3.2 Technologies	Firewalls, IDS/IPS, antivirus, TPM/HSM, and EDR form the technical layer of defence against cyber threats.
10.3.3 Culture	Security awareness training, phishing simulations, and a blame-free reporting culture make people a strength, not a weakness.	10.3.5 Policies	AUP, information security, password, and incident response policies define the rules everyone must follow.
10.3.6 Standards	ISO 27001, NIST CSF, PCI-DSS, HIPAA, and CIS Controls provide measurable security benchmarks and frameworks.	10.3.8 Guidelines	Recommended best practices for passwords, email, remote work, patching, and clean-desk habits guide secure behaviour.
10.3.9 Procedures	Step-by-step procedures for incident response, account management, patching, backup, and secure disposal ensure consistency.		